

FULL BLACK – BOX PENETRATION TESTING REPORT

W4-PM — Web & PDF Security Penetration Testing CYBERSECURITY | NETWORKWALKS

Field	Details
Report Title	Penetration Testing & Security Assessment Report
Client Name	Mediroza General Hospital
Target URL / Domain	https://medirozahospital.com
Program / Batch	Batch B083 – Networkwalks
Module	Week 4 – Web & PDF Security Penetration Testing
Engagement Type	Full Black-box Penetration Test
Duration	5 Days
Tools Used	Kali Linux, Zenmap (Nmap), Web Browser, SQL Injection (SQLi), pdf2john, John the Ripper, rockyou.txt, Networkwalks Online Cracker

1. Liability Disclaimer & Engagement Scope

- **Authorization & Scope:** Testing was conducted strictly within the authorized scope on <https://medirozahospital.com> following written client authorization. Testing was limited to web infrastructure, data extraction, and password assessment.
 - **Rules of Engagement:** Social engineering, denial of service (DoS), and testing outside the agreed domain scope were strictly prohibited.
 - **Disclaimer Statement:** All activities were executed in a controlled environment for authorized security evaluation and educational purposes.
-

2. Executive Summary & Project Introduction

- **Project Objective:** Conduct a 5-day black-box penetration test against Mediroza General Hospital to identify infrastructure vulnerabilities, exploit authentication flaws, assess PDF password security, and evaluate server data exposure risks.
- Summary of Milestones Completed:
 1. **Milestone 1 (Initial Access):** Bypassed patient portal authentication using SQL Injection (SQLi) and retrieved 3 encrypted patient laboratory reports.
 2. **Milestone 2 (Data Extraction & Cracking):** Extracted password hashes and recovered passwords for all 3 patient PDF files using dictionary attacks.
 3. **Milestone 3 (Critical Data Exposure):** Discovered an unlinked web directory containing an unencrypted database backup file (mediroza_db_backup_2019.sql), uncovering employee salaries and hospital shareholder structures.
 4. **Milestone 4 (Reporting):** Compiled findings, evidence screenshots, risk ratings, and remediation steps into this formal report.

3. Tools Used & Technical Methodology

Tool	Purpose / Function in Engagement
Zenmap (Nmap)	Conducted network port scanning and domain topology reconnaissance.
Web Browser (Firefox)	Interacted with the patient portal, executed SQL Injection payloads, and browsed server directories.
SQL Injection (SQLi)	Bypassed authentication mechanisms on patient/login.php.
pdf2john	Extracted password hashes from protected PDF laboratory files into text format.
John the Ripper (JTR)	Executed dictionary-based hash cracking locally using Kali Linux wordlists.
rockyou.txt	Default dictionary wordlist used for testing candidate passwords.
Networkwalks Online Cracker	Web-based online tool used to process PDF hashes and crack passwords.

4. Activities Performed & Proof of Exploitation

4.1 Milestone 1 (M1) — Network Reconnaissance & Initial Web Access

- **Network Reconnaissance:**
 - Scanned target domain medirozahospital.com (199.188.201.16 / 10.19.13.58) using Zenmap.

- Identified open services, including port 53/tcp (domain).
- **Web Exploitation (SQL Injection):**
 - Navigated to the Patient Portal login page at <https://medirozahospital.com/patient/login.php>.
 - Submitted the SQL Injection authentication bypass payload: admin'-- in the username field.
 - Successfully bypassed authentication to gain unauthorized access to /patient/portal.php.

- **Retrieved PDF Reports:**

1. Pathology Report - S. Dlamini (Lab Ref: LR-2024-1187)
2. Pathology Report - P. Reddy (Lab Ref: LR-2024-1192)
3. Pathology Report - E. Thompson (Lab Ref: LR-2024-1205)

4.2 Milestone 2 (M2) — PDF Encryption Cracking & Patient Record Inspection

- **Hash Extraction & Password Cracking:**

- Hashes were extracted from the downloaded PDF files using pdf2john and processed via dictionary attacks.
- Recovered Passwords:
 - Report 1 (patient_report_1.pdf - Sipho Dlamini): Password recovered = 123456
 - Report 2 (patient_report_2.pdf - Priya Reddy): Password recovered = password
 - Report 3 (patient_report_3.pdf - Emily Thompson): Password recovered = !@#\$\$%^&

- **Decrypted Patient Data Content:**

- Sipho Dlamini (ID: MG-P-10231, DOB: 1984-06-12): White Cell Count elevated at $11.8 \times 10^9/L$ (HIGH).
- Priya Reddy (ID: MG-P-10244, DOB: 1991-02-28): Total Cholesterol 6.4 mmol/L (HIGH), LDL Cholesterol 4.1 mmol/L (HIGH), Triglycerides 1.8 mmol/L (HIGH).
- Emily Thompson (ID: MG-P-10258, DOB: 1978-09-03): Haemoglobin 11.4 g/dL (LOW), Ferritin 9 ug/L (LOW), Vitamin D 42 nmol/L (LOW).

4.2.1: Analysis of 3rd PDF Password Complexity & Recovery (!@#\$\$%^&)

- **Target Document:** patient_report_3.pdf (Pathology Report for Emily Thompson, Lab Ref: LR-2024-1205).
- **Recovered Passphrase:** !@#\$\$%^&
- **Complexity & Resistance Analysis:**

- **Baseline Wordlist Limitations:** Standard dictionary attacks using common wordlists (such as rockyou.txt) or default web-based cracking lists quickly recover standard alphanumeric passwords (e.g., 123456 or password). However, patient_report_3.pdf utilized a special-character sequence (!@#\$%^&;) consisting entirely of non-alphanumeric symbols.
- **Extended Rule & Mask Attack:** Because baseline dictionary lists prioritize dictionary words and appended trailing digits, standard wordlist passes failed to yield an immediate match.
- **Recovery Workflow:** Hash extraction was performed using pdf2john, followed by an extended character-set/mask attack in John the Ripper (targeting special symbol combinations corresponding to top-row keyboard shift sequences), successfully recovering !@#\$%^&.
- **Security Insight:** Although !@#\$%^&; follows a physical pattern on a standard QWERTY keyboard (Shift + 1 through 7), the inclusion of non-alphanumeric symbols increases entropy relative to standard dictionary words, demonstrating why complex character sets resist simple wordlist attacks

4.3: Milestone 3 (M3) — Endpoint Reconnaissance via robots.txt & Database Backup Exposure

- **Reconnaissance Methodology (robots.txt Inspection):**
 - During web application mapping, the target's /robots.txt file (<https://medirozahospital.com/robots.txt>) was inspected to discover hidden or unlinked sub-endpoints.
 - While robots.txt is intended to instruct web crawlers on which directories not to index, security auditors evaluate it during black-box penetration testing to locate sensitive paths left exposed by administrators.
 - Inspecting /robots.txt revealed a disallowed path pointing to the /old/ web endpoint.
- **Directory Indexing Flaw:**
 - Navigating directly to <https://medirozahospital.com/old/> confirmed an open directory listing flaw on the LiteSpeed/Apache web server.
 - An unencrypted database backup dump file named mediroza_db_backup_2019.sql was found publicly accessible and downloadable.
- **Uncovered Critical Data:**
 - **Employee Salaries (staff table):**
 - Dr. Johan van der Merwe (Medical Director): 160,000 ZAR/month
 - Sarah Botha (Chief Financial Officer): 152,000 ZAR/month
 - Dr. Rajesh Naidoo (Chief Pathologist): 138,000 ZAR/month
 - Dr. Anita Naicker (Consultant Cardiologist): 132,000 ZAR/month

- Dr. Ahmed Kara (Consultant Physician): 128,000 ZAR/month
- Michael Roberts (HR Director): 96,000 ZAR/month
- Dr. Yusuf Cassim (Senior Registrar): 74,000 ZAR/month
- **Shareholder Structure & Equity Holdings (shareholders table):**
 - Dr. Rajesh Naidoo: 18.0% Ordinary shares (180,000 shares)
 - Cedar Health Holdings (Pty) Ltd: 15.0% Ordinary shares (150,000 shares)
 - Dr. Johan van der Merwe: 12.8% Ordinary shares (128,000 shares)
 - Reddy Family Trust: 11.0% Ordinary shares (110,000 shares)
 - Thabo Molefe: 10.0% Ordinary shares (100,000 shares)
 - Sarah Botha: 9.0% Ordinary shares (90,000 shares)
 - Dr. Ahmed Kara: 8.0% Preferential shares (80,000 shares)
 - Naledi Zulu: 7.0% Ordinary shares (70,000 shares)

5. Summary of Results & Risk Rating

Vulnerability / Finding	Affected Target	Severity / Risk Rating	Justification
SQL Injection (Authentication Bypass)	/patient/login.php	CRITICAL	Allows complete bypass of authentication mechanisms to reach confidential patient lab files.
Sensitive File & SQL Backup Leak	/old/mediroza_db_backup_2019.sql	CRITICAL	Public directory listing exposes full employee salaries, PII, and hospital shareholder equity details.
Weak PDF Encryption & Passwords	Patient Lab PDFs	HIGH / MEDIUM	Short/dictionary passwords (123456, password) allow rapid recovery of encrypted patient reports via wordlists.

File / Document	Patient Name	Hash Extraction Method	Recovered Password	Verification Status
patient_report_1.pdf	Sipho Dlamini	pdf2john / Online Extractor	123456	Opened & Verified
patient_report_2.pdf	Priya Reddy	pdf2john / Online Extractor	password	Opened & Verified
patient_report_3.pdf	Emily Thompson	pdf2john / Symbol Mask Attack	!@#\$\$%^&	Opened & Verified

6. Recommendations & Remediation Actions

1. Fix SQL Injection Vulnerability:
 - Implement parameterized queries and prepared statements (e.g., PDO in PHP) across all web login inputs.
 - Disable direct concatenation of user input in SQL database queries.
2. Secure Server Files & Web Directories:
 - Disable directory browsing globally across web server configurations (e.g., Options -Indexes in Apache / LiteSpeed).
 - Immediately delete database backups (*.sql) from publicly accessible web directories.
3. Enforce Strong PDF Password Policies:
 - Enforce strong, unpredictable passphrases for medical document security rather than simple dictionary terms.
 - Utilize modern AES encryption standards for exported PDF files.

7. Conclusion

The black-box penetration testing assessment successfully achieved all project milestones. Critical vulnerabilities were identified in authentication handling and web server directory controls, leading to unauthorized access to patient records and financial data. Implementation of the provided remediation steps will significantly harden Mediroza General Hospital's security posture.

8. Evidences Collected







